

Certified Enterprise Risk Professional (CERP) Exam Question Bank

200 Multiple-Choice Questions with Answers

Based on ABA CERP Exam Content Outline
Domains 1-8: Risk Governance & Risk Management

Total Questions: 200

Time Allowed (Simulated): 4 Hours

June 13, 2026

Instructions

- This question bank contains 200 multiple-choice questions covering all CERP exam domains.
- Each question has one correct answer indicated in **bold** after the question.
- The actual CERP exam allows 4 hours for 200 questions.
- Domains: Risk Governance (Domain 1-4) and Risk Management (Domain 5-8).

1 RISK GOVERNANCE

1.1 Domain 1: Board and Senior Management Oversight (Questions 1-16)

1. What is the primary role of the Board of Directors in enterprise risk management? A) Implement daily risk limits
B) Provide oversight and approve risk appetite
C) Execute risk mitigation strategies
D) Manage third-party vendor risks

Answer: B

2. Which concept involves the ability of risk management staff to question assumptions and decisions made by business lines? A) Risk tolerance
B) Credible challenge
C) Control environment
D) Risk velocity

Answer: B

3. How does risk culture link to corporate strategy? A) It replaces the need for written policies
B) It influences how employees make risk-reward trade-offs
C) It only applies to the compliance department
D) It determines the bank's tax strategy

Answer: B

4. Which practice BEST drives organizational change in risk culture? A) Issuing a single memo on policies
B) Communicating expectations and defining clear roles
C) Outsourcing all risk management to consultants
D) Increasing capital requirements

Answer: B

5. Within the three lines of defense, who owns risk management? A) Internal audit (third line)
B) Compliance (second line)
C) Business operations (first line)
D) The Board of Directors

Answer: C

6. What is a key component of risk appetite? A) The bank's preferred coffee brand
B) The types and amount of risk an organization is willing to accept
C) The exact date of the next audit
D) The CEO's personal investment portfolio

Answer: B

7. Which committee is typically responsible for reviewing risk appetite statements quarterly? A) The HR Committee
B) The Marketing Committee
C) The Risk Committee of the Board
D) The Facilities Committee

Answer: C

8. What does "tone at the top" refer to? A) The highest interest rate on loans
B) Leadership's commitment to ethical behavior and risk awareness
C) The volume of the fire alarm system
D) The bank's tallest building

Answer: B

9. Which is an example of a qualitative risk appetite statement? A) "Maintain Tier 1 capital above 10%"
B) "We will not engage in reputational risk activities that harm customer trust"
C) "Limit operational losses to \$5 million annually"
D) "Keep loan-to-deposit ratio under 90%"

Answer: B

10. Senior management's risk oversight responsibility includes: A) Only reviewing credit risk
B) Ensuring risk policies align with strategic objectives
C) Preparing individual tax returns
D) Designing the bank's website

Answer: B

11. The concept of "risk culture" is BEST described as: A) A written document
B) The shared values, attitudes, and behaviors about risk

- C) A software system
- D) The external audit report

Answer: B

- 12.** How should risk appetite be communicated to employees? A) Only to the Board
B) Through training, policies, and performance metrics
C) Verbally on the trading floor only
D) It should remain confidential

Answer: B

- 13.** What is a primary responsibility of senior management regarding risk information?
A) Conceal negative information
B) Provide relevant, timely, and accurate risk information to the Board
C) Only report positive trends
D) Delay reporting until quarterly meetings

Answer: B

- 14.** Which role does the "second line of defense" play? A) Executes transactions
B) Provides oversight, compliance, and risk management functions
C) Conducts independent audits
D) Manages customer service

Answer: B

- 15.** Credible challenge requires: A) Agreement with all management decisions
B) Independent analysis and willingness to question
C) Avoiding all conflicts
D) Only questioning external parties

Answer: B

- 16.** Risk appetite is directly linked to: A) Only regulatory capital
B) Corporate strategy and operations
C) The bank's logo design
D) Employee vacation schedules

Answer: B

1.2 Domain 2: Policies, Procedures and Limits (Questions 17-40)

- 17.** What is an element of an effective control environment? A) No written policies
B) Regular policy review and governance
C) Unlimited exceptions
D) Verbal approvals only

Answer: B

- 18.** Regulatory expectations around risk policies require: A) No approval authority
B) Proper authority and breadth of coverage
C) Policies written only for credit risk
D) No periodic review

Answer: B

- 19.** What is a typical source of risk concentration? A) Diversified portfolio
B) High number of small loans
C) Uninsured deposits
D) Low counterparty exposure

Answer: C

- 20.** How should a policy exception for loan-to-value (LTV) be documented? A) Verbally with the borrower
B) With appropriate approval authority and rationale
C) It does not need documentation
D) Only if the exception is approved

Answer: B

- 21.** What is the proper process for a policy breach (e.g., data privacy breach)? A) Ignore if small
B) Escalate, document, and track
C) Only report to marketing
D) Fix quietly without reporting

Answer: B

- 22.** Policy limits for measuring business performance should be: A) Set once and never changed
B) Developed and maintained with periodic review

- C) Hidden from business lines
- D) Based only on competitor actions

Answer: B

- 23.** Which is a quantitative risk metric? A) Employee satisfaction
B) Value at Risk (VaR)
C) Brand reputation
D) Ethical culture

Answer: B

- 24.** What is an appropriate approval authority for a policy exception? A) Any employee
B) A designated level of management based on exception size/risk
C) The external auditor
D) The borrower

Answer: B

- 25.** What should a risk management policy clearly state? A) Only the bank's mission
B) Purpose, roles, responsibilities, and escalation channels
C) Employee vacation policy
D) Marketing strategy

Answer: B

- 26.** A risk appetite framework includes: A) Only qualitative measures
B) Qualitative and quantitative components linked to strategy
C) Only operational losses
D) No monitoring thresholds

Answer: B

- 27.** How are risk appetite levels assessed? A) By guessing
B) Using thresholds and limits relative to capital and earnings
C) Only during a crisis
D) By external vendors only

Answer: B

- 28.** Regulator expectations for procedures require: A) No alignment with policies

- B) Procedures that execute in alignment with risk management policies
- C) Procedures that contradict policies
- D) No written procedures

Answer: B

- 29.** What is a policy limit for credit risk? A) Maximum loan-to-value ratio allowed
- B) Employee dress code
 - C) Office hours
 - D) Marketing budget

Answer: A

- 30.** How should noncompliance with policy be managed? A) Always terminate the employee
- B) Establish timelines and processes for exceptions or risk mitigation
 - C) Ignore first offenses
 - D) Automatically approve all exceptions

Answer: B

- 31.** What is the purpose of escalation channels in risk management? A) To slow down decision-making
- B) To route issues to appropriate authority for resolution
 - C) To avoid responsibility
 - D) To bypass management

Answer: B

- 32.** Periodic review of policy limits should consider: A) Only historical performance
- B) Current risk environment, strategy, and performance
 - C) Employee preferences
 - D) Competitor logos

Answer: B

- 33.** Which is an example of risk concentration in counterparty risk? A) Many small counterparties
- B) Heavy exposure to a single derivative counterparty
 - C) Diversified investments
 - D) Low notional amounts

Answer: B

- 34.** What is the first step in establishing a risk management policy? A) Send to all employees
B) Align with enterprise objectives and risk appetite
C) Ignore regulatory requirements
D) Copy from another bank

Answer: B

- 35.** A policy exception log should include: A) Only the date
B) Description, rationale, approver, and date
C) Employee home address
D) Customer favorite color

Answer: B

- 36.** What is a breach in policy? A) Following policy exactly
B) Violation of a policy requirement
C) An approved exception
D) A new policy

Answer: B

- 37.** Who should approve a material policy exception? A) The borrower
B) The vendor
C) Appropriate senior management or committee
D) The external auditor

Answer: C

- 38.** What is a typical quantitative risk appetite metric? A) "Be ethical"
B) Maintain CET1 capital ratio above 9.5%
C) "Treat customers fairly"
D) "Be a good employer"

Answer: B

- 39.** Policy governance should include: A) No version control
B) Documented approval, review cycles, and version control
C) Verbal updates only
D) Annual disposal of all policies

Answer: B

40. What is the consequence of weak policy limits? A) Stronger risk culture
B) Potential for excessive risk-taking and losses
C) Reduced regulatory scrutiny
D) Higher profitability

Answer: B

41. What is a policy limit for market risk? A) Loan-to-value ratio
B) Maximum daily Value at Risk (VaR) limit
C) Employee turnover rate
D) Customer satisfaction score

Answer: B

42. An effective risk management policy should be: A) Written in legal jargon only
B) Communicated and accessible to relevant staff
C) Stored in a locked safe
D) Only available to the Board

Answer: B

43. What is the role of the Board regarding policy limits? A) Implement daily limits
B) Approve significant limits and exceptions
C) Execute trades
D) Ignore limit breaches

Answer: B

44. A risk concentration in uninsured deposits represents: A) Low risk
B) Funding concentration risk
C) No risk
D) Operational risk only

Answer: B

45. When should a policy be reviewed? A) Never
B) Periodically and following significant events
C) Only when regulators visit

D) Only after a loss

Answer: B

1.3 Domain 3: Management Information Systems (Questions 41-55)

46. What is a key design element in MIS reports for effective decision-making? A) Irrelevant data

B) Timeliness, accuracy, consistency, completeness, and relevance

C) Only historical data

D) No aggregation

Answer: B

47. Which is an investigative approach to ensure systems function as expected? A) Blind trust

B) Inquiry, observation, and documentation review

C) Ignoring user feedback

D) Only automated testing without review

Answer: B

48. Data governance ensures: A) Data can be changed by anyone

B) Completeness and accuracy of reporting

C) No data retention

D) Unlimited access to all data

Answer: B

49. What is a fundamental system requirement for ALM (Asset Liability Management)?

A) Marketing automation

B) Modeling of interest rate risk and liquidity

C) HR payroll system

D) Customer relationship management

Answer: B

50. How can the integrity of model inputs be confirmed? A) Blind acceptance

B) Model validation and reconciliation

C) Ignoring outliers

D) Using only manual inputs

Answer: B

- 51.** Which is a system limitation in risk reporting? A) Perfect data quality
B) Access restrictions or manual vs. automated reporting gaps
C) Unlimited processing power
D) Real-time all the time

Answer: B

- 52.** What is an example of risk aggregation analysis? A) Looking at each loan individually
B) Summing exposures across business lines to see total concentration
C) Ignoring correlations
D) Only reviewing credit risk

Answer: B

- 53.** What is a quality control process for data? A) No validation
B) Reconciliation of source system to report output
C) Allowing any user to edit data
D) No accountability

Answer: B

- 54.** MIS reports for risk management should include: A) Only favorable trends
B) Risk metrics, limit utilization, and exception reporting
C) Employee birthdays
D) Office supply inventory

Answer: B

- 55.** What is a regulatory expectation for risk information systems? A) No standards
B) Sound practices for data integrity and security
C) Only manual processes
D) No independent validation

Answer: B

- 56.** How do you challenge the integrity of system outputs? A) Assume they are always right
B) Compare to independent sources or perform reasonability tests

- C) Ignore anomalies
- D) Only review once per year

Answer: B

- 57.** Data accessibility in risk reporting means: A) Everyone has access to all data
B) Authorized users can obtain data when needed
C) Data is never available
D) Only external auditors can see data

Answer: B

- 58.** What is the purpose of a data governance program? A) To reduce data quality
B) To ensure data is accurate, complete, and fit for purpose
C) To delete all data
D) To allow unlimited data changes

Answer: B

- 59.** Which is a control for information systems providing risk data? A) No access controls
B) User authentication and segregation of duties
C) Unlimited write access
D) No logging

Answer: B

- 60.** What is a key consideration for data retention? A) Keep everything forever
B) Regulatory, legal, and business requirements
C) Delete immediately after use
D) No retention policy

Answer: B

1.4 Domain 4: Control Framework (Questions 56-70)

- 61.** What are the three lines of defense? A) Operations, IT, HR
B) Business management, risk/compliance, internal audit
C) Vendors, customers, regulators
D) Tellers, loan officers, managers

Answer: B

- 62.** COSO Integrated Control Framework includes which component? A) Only monitoring
B) Control environment, risk assessment, control activities, information/communication, monitoring
C) Only financial reporting
D) Only fraud prevention

Answer: B

- 63.** Which is a preventative control? A) Detective review after transaction
B) Approval requirement before transaction
C) Reconciliation after the fact
D) Investigation of loss

Answer: B

- 64.** What is "effective challenge" by risk management staff? A) Agreeing with everything
B) Critically questioning risk assessments and assumptions
C) Avoiding all discussions
D) Only challenging external parties

Answer: B

- 65.** SOX (Sarbanes-Oxley Act) primarily addresses: A) Marketing controls
B) Internal controls over financial reporting
C) Customer service
D) Human resources

Answer: B

- 66.** Quality assurance (QA) in risk management is: A) A one-time activity
B) Ongoing review of control effectiveness
C) Only for IT systems
D) Not required for banks

Answer: B

- 67.** How should risk management reviews be coordinated with control partners? A) Siloed, no coordination
B) Coordinate timing, coverage, and scope to avoid duplication
C) Only after losses occur
D) Exclusively by external consultants

Answer: B

- 68.** Which is a detective control? A) Pre-approval
B) Reconciliation of accounts after transaction
C) Segregation of duties
D) Physical security

Answer: B

- 69.** What is a principle for effective exam management? A) Hide negative information
B) Be transparent, organized, and responsive
C) Delay responses
D) Only provide partial data

Answer: B

- 70.** Heightened Standards (e.g., SR 08-08) apply to: A) All community banks
B) Large, complex financial institutions
C) Credit unions only
D) Non-financial firms

Answer: B

- 71.** Internal audit (third line) must be: A) Part of business operations
B) Independent of management
C) Responsible for risk-taking
D) The same as compliance

Answer: B

- 72.** Control activities should be: A) Irrelevant to risk assessment
B) Designed based on risk assessment
C) The same for all banks
D) Never documented

Answer: B

- 73.** Which is a control for model risk? A) No validation
B) Independent model validation and governance
C) Using only one model

D) No documentation

Answer: B

- 74.** The internal control framework should align with: A) Only the CEO's preferences
B) Size, complexity, and risk appetite of the organization
C) The smallest bank's framework
D) No regulatory requirements

Answer: B

- 75.** What is the role of the first line in controls? A) Audit the controls
B) Design and implement controls in business processes
C) Set risk appetite for the whole bank
D) Only monitor, not implement

Answer: B

2 RISK MANAGEMENT

2.1 Domain 5: Risk Identification (Questions 71-95)

- 76.** Which is an operational risk event? A) Loan default
B) Processing error
C) Interest rate change
D) Stock market crash

Answer: B

- 77.** What is an upstream impact of a risk event? A) Only customer impact
B) Effect on preceding processes or causes
C) Only financial loss
D) Only reputational damage

Answer: B

- 78.** Which is a risk presented by third parties? A) No risk
B) Concentration risk and financial health of vendor
C) Only credit risk
D) Only market risk

Answer: B

- 79.** What is the definition of materiality in risk management? A) Any risk
B) The significance of a risk event that would influence decisions
C) Only risks over \$1 million
D) Only reputational risks

Answer: B

- 80.** Which is a credit risk event? A) System downtime
B) Loan default
C) Employee fraud
D) Regulatory fine

Answer: B

- 81.** A risk and control self-assessment (RCSA) evaluates: A) Only inherent risk
B) Inherent risk, control environment, and residual risk
C) Only residual risk
D) Only operational losses

Answer: B

- 82.** What is an idiosyncratic risk? A) Market-wide risk
B) Unique risk specific to a product line or relationship
C) Systematic risk
D) Interest rate risk

Answer: B

- 83.** Which is a potential regulatory action for failure to meet requirements? A) Thank you letter
B) Matters Requiring Attention (MRA) or Civil Money Penalty (CMP)
C) Bonus payment
D) Extended deadline

Answer: B

- 84.** What is a risk presented by customer concentration? A) Diversification benefit
B) High dependency on few customers

- C) Low default rates
- D) Stronger negotiation power

Answer: B

- 85.** Which is a type of risk event? A) Only financial risks
B) Processing errors, loan default, fraud, compliance failures
C) Only external events
D) Only internal events

Answer: B

- 86.** How do you identify emerging risks? A) Only look backward
B) Monitor internal and external environment, industry trends, regulatory changes
C) Ignore external signals
D) Only review once per year

Answer: B

- 87.** What is inherent risk? A) Risk after controls
B) Risk before considering controls
C) Risk transferred to insurer
D) No risk

Answer: B

- 88.** What is residual risk? A) Risk before controls
B) Risk remaining after risk responses and controls
C) Only operational risk
D) Only credit risk

Answer: B

- 89.** An RCSA typically starts with: A) Audit findings
B) Business process mapping
C) External benchmarks
D) Competitor analysis

Answer: B

- 90.** Which is a third-party risk concentration? A) Many small vendors

- B) Single vendor for critical service
- C) Internal controls
- D) Diversified suppliers

Answer: B

- 91.** A downstream impact of a risk event refers to: A) The root cause
B) Effects on subsequent processes or customers
C) Only immediate loss
D) Only employee impact

Answer: B

- 92.** What is the regulatory environment for banks regarding risk identification? A) No requirements
B) Expectation to identify and manage all material risks
C) Only identify credit risk
D) Only identify market risk

Answer: B

- 93.** Which is a risk resulting from failure to meet customer requirements? A) Higher customer loyalty
B) Reputational damage and potential regulatory action
C) Lower costs
D) Increased efficiency

Answer: B

- 94.** What is the purpose of surveying the external environment? A) To ignore trends
B) To identify emerging risks like new regulations or competitors
C) To copy competitors blindly
D) To reduce innovation

Answer: B

- 95.** Which is a credit risk indicator? A) System uptime
B) Non-performing loan ratio
C) Employee turnover
D) Marketing spend

Answer: B

- 96.** Materiality criteria should consider: A) Only quantitative factors
B) Both quantitative (financial) and qualitative (reputation, compliance) factors
C) Only qualitative factors
D) Only regulatory fines

Answer: B

- 97.** A control self-assessment evaluates: A) Only inherent risk
B) Effectiveness of controls in mitigating risk
C) Only market conditions
D) Only external factors

Answer: B

- 98.** Which is a unique product line risk? A) Standard mortgage
B) Complex derivative product with limited understanding
C) Simple savings account
D) Basic checking account

Answer: B

- 99.** What is a key source for identifying operational risk? A) Only external benchmarks
B) Internal loss data, RCSA, and scenario analysis
C) Only competitor data
D) Only regulatory fines

Answer: B

- 100.** Which is an example of a processing error? A) Loan approval
B) Incorrect data entry leading to misstatement
C) Interest rate change
D) Customer deposit

Answer: B

2.2 Domain 6: Risk Measurement and Evaluation (Questions 96-120)

- 101.** What are key risk assessment factors? A) Only likelihood
B) Likelihood, impact, direction, and velocity

- C) Only impact
- D) Only velocity

Answer: B

- 102.** What is a Key Risk Indicator (KRI)? A) A marketing metric
B) A metric used to measure and monitor risk exposure
C) An HR metric
D) A facility metric

Answer: B

- 103.** Scenario analysis (stress testing) is used to: A) Only comply with regulations
B) Assess impact of hypothetical adverse events
C) Predict exact outcomes
D) Ignore tail risks

Answer: B

- 104.** What is the difference between inherent risk and residual risk? A) No difference
B) Inherent risk is before controls, residual risk is after controls
C) Residual risk is always higher
D) Inherent risk is after controls

Answer: B

- 105.** A KPI (Key Performance Indicator) measures: A) Risk only
B) Performance relative to objectives
C) Only compliance
D) Only losses

Answer: B

- 106.** Which external factor should be considered in risk measurement? A) Employee morale
B) Economic conditions like unemployment rate
C) Office furniture
D) Internal policies only

Answer: B

- 107.** Risk velocity refers to: A) The size of risk
B) The speed at which a risk can materialize
C) The color of the risk
D) The location of risk

Answer: B

- 108.** How is residual risk calculated? A) Inherent risk + controls
B) Inherent risk minus control effectiveness
C) Only inherent risk
D) Only controls

Answer: B

- 109.** What is a limitation of stress testing? A) It is perfectly accurate
B) It relies on assumptions and historical correlations which may break down
C) It is too easy
D) It requires no data

Answer: B

- 110.** Which is a credit KRI? A) System downtime
B) Debt-to-income ratio trends
C) Employee turnover
D) Marketing ROI

Answer: B

- 111.** Risk scoring and prioritization in RCSA is based on: A) Only impact
B) Likelihood and impact combined
C) Only likelihood
D) Random assignment

Answer: B

- 112.** How do you evaluate risk relative to risk appetite? A) No comparison needed
B) Compare risk levels to approved thresholds and triggers
C) Only compare after a loss
D) Only at year-end

Answer: B

- 113.** What is a trigger in risk measurement? A) A gun
B) A predetermined level that, when breached, requires action
C) A type of control
D) A risk response

Answer: B

- 114.** Scenario analysis triggers could include: A) Employee birthdays
B) Economic indicators hitting certain levels
C) Office move dates
D) Marketing campaign launches

Answer: B

- 115.** Aggregated risks can have: A) No effect
B) Correlated effects that amplify overall risk
C) Only additive effects
D) Only independent effects

Answer: B

- 116.** Which is a financial KPI? A) Operational losses
B) Return on Equity (ROE)
C) System downtime
D) Employee satisfaction

Answer: B

- 117.** What is the purpose of calculating risk metrics? A) To ignore risk
B) To quantify risk exposures for decision-making
C) To create paperwork
D) To avoid accountability

Answer: B

- 118.** A risk appetite statement might set a limit for: A) Employee lunch breaks
B) Maximum acceptable credit loss rate
C) Office square footage
D) Number of holidays

Answer: B

- 119.** Which is a key indicator for liquidity risk? A) Loan-to-deposit ratio
B) Employee count
C) Number of branches
D) Marketing spend

Answer: A

- 120.** When conducting scenario analysis, regulators expect: A) No documentation
B) Scenarios that are severe but plausible based on bank's complexity
C) Only historical scenarios
D) Only optimistic scenarios

Answer: B

- 121.** Risk direction refers to: A) North/south
B) Whether risk has upside or downside impact
C) Only downside
D) Only upside

Answer: B

- 122.** Which is an example of an aggregated risk effect? A) Credit risk and operational risk are unrelated
B) A cyber event causing operational disruption and reputational damage (multiple risks combined)
C) Only one risk matters
D) Risks cancel each other out

Answer: B

- 123.** What is a control environment evaluation? A) Ignoring controls
B) Assessing whether controls are designed and operating effectively
C) Only looking at control cost
D) Only looking at control owner

Answer: B

- 124.** Which is a key indicator for market risk? A) Loan default rate
B) Interest rate sensitivity (duration gap)
C) Employee turnover
D) Customer complaints

Answer: B

- 125.** Stress testing for a community bank might focus on: A) Complex global scenarios
B) Local economic downturn and loan defaults
C) Space weather
D) Alien invasion

Answer: B

Answer Key Summary

1. B	11. B	21. B	31. B
2. B	12. B	22. B	32. B
3. B	13. B	23. B	33. B
4. B	14. B	24. B	34. B
5. C	15. B	25. B	35. B
6. B	16. B	26. B	36. B
7. C	17. B	27. B	37. B
8. B	18. B	28. B	38. B
9. B	19. C	29. B	39. B
10. B	20. B	30. B	40. B